

บทที่ 6

บทวิจารณ์และสรุป

6.1 บทสรุป

การโจมตีโดยอาศัยช่องโหว่ทางซอฟต์แวร์ (Exploit) มีความนิยมในการใช้โจมตีมากขึ้น ดังจะเห็นได้จากการประกาศเตือนมากมายตามเว็บไซต์ที่เกี่ยวกับความปลอดภัยต่างๆ โดยรูปแบบในการโจมตีใหม่ๆ ก็จะถูกคิดค้นขึ้นมาหลากหลายมากเช่นเดียวกัน ดังนั้นจึงต้องหาวิธีในการป้องกันการเข้าโจมตีให้เท่าทันผู้โจมตี เพื่อป้องกันความเสียหายให้แก่ระบบ

การเขียนโปรแกรมโดยคำนึงถึงความปลอดภัยเป็นสิ่งที่ง่ายที่สุดในการป้องกันการถูกโจมตี เนื่องจากผู้โจมตีจะไม่สามารถหาช่องทางที่จะเจาะเข้ามาในระบบเข้ามาได้ แต่อย่างไรก็ตาม ในการเขียนโปรแกรมที่มีขนาดใหญ่ ย่อมต้องมีความผิดพลาดเกิดขึ้นได้ วิธีการป้องกันจึงเปลี่ยนไปเป็นการป้องกัน stack เพื่อทำการกำจัดโปรเซสที่ถูกบุกรุก ทำให้ผู้ดูแลระบบสามารถเข้าใจได้ในระดับหนึ่ง แต่ที่สำคัญที่สุดคือการ update โปรแกรมให้ทันสมัยอยู่เสมอ เพื่อปิดช่องโหว่ใดๆ อันเกิดจากโปรแกรมนั้นไม่ให้ผู้บุกรุกสามารถโจมตีเราได้นั่นเอง

6.2 วิเคราะห์สิ่งที่ได้จากโครงงาน

การโจมตีโดยอาศัยช่องโหว่ทางซอฟต์แวร์ จะอาศัยความผิดพลาดของโปรแกรมเมอร์ที่เขียนโปรแกรมโดยไม่ระมัดระวังในการใช้ฟังก์ชัน การประกาศตัวแปร เป็นต้น ซึ่งเมื่อความผิดพลาดเกิดขึ้น อาจจะนำไปสู่การบุกรุกของผู้โจมตี โดยผู้โจมตีสามารถที่จะได้สิทธิ์ root (root privilege) รวมไปถึงการทำให้ระบบล่ม (Denial Of Services) ซึ่งสามารถก่อให้เกิดความเสียหายได้เป็นอันมาก ในเมื่อเราไม่ได้เป็นผู้เขียนโปรแกรมบางโปรแกรมในระบบ จึงไม่สามารถเข้าไปแก้ไขอะไรได้ จึงเปลี่ยนวิธีป้องกันโดยการเฝ้าดู stack ซึ่งจะทำให้การหาขนาดของบัฟเฟอร์ โดยดูจากตำแหน่งของตัวแปรเทียบกับตำแหน่งของตัวชี้ stack (stack pointer) ซึ่งเมื่อใดก็ตามที่โปรแกรมพยายามที่จะเขียนข้อมูลลงบนตัวแปร แต่ล้นไปจนถึงตัวชี้ stack (stack pointer) โปรแกรมจะทำการกำจัดโปรเซสนั้นทิ้งในทันที ทำให้สามารถป้องกันการโจมตีได้

6.3 ปัญหาอุปสรรคและแนวทางในการแก้ไข

1. โปรแกรม Lancelot Guard สามารถป้องกันการโจมตีแบบ stack overflow ได้เท่านั้น แต่ไม่สามารถป้องกันการโจมตีแบบ heap overflow ในการที่จะป้องกันได้นั้นต้องใช้การป้องกันขณะคอมไพล์ โดยทำการแพทช์โปรแกรม gcc ให้สร้างพื้นที่สำหรับตรวจสอบระหว่างตัวแปรแบบ heap เป็นต้น

2. ในการเขียนโค้ด สามารถเขียนได้หลายแบบ ทำให้การตรวจสอบโดย โปรแกรม Lancelot Scan อาจเกิดข้อผิดพลาดได้
3. โปรแกรม Lancelot Scan สามารถตรวจสอบได้เพียงภาษา C
4. ในปัจจุบันการบุกรุกเว็บไซต์สามารถทำได้ยากขึ้น เพราะโปรแกรมที่ใช้พัฒนาได้มีการแก้ไขข้อผิดพลาดต่างๆขึ้นเยอะ ทำให้ไม่สามารถบุกรุกได้ทุกเว็บไซต์

6.4 แนวทางการพัฒนาต่อ

1. พัฒนาโปรแกรมที่สามารถป้องกัน Heap โอเวอร์โฟลว์ได้ โดยอาศัยหลักการแพทช์ โปรแกรม gcc
2. พัฒนาโปรแกรม Lancelot Scan ให้สามารถรองรับรูปแบบการเขียนโปรแกรมที่ถูกต้องตามหลักการเขียนภาษา C
3. พัฒนาโปรแกรม Lancelot Scan ให้สามารถรองรับได้หลายภาษา เช่น C++, JAVA เป็นต้น
4. หาวิธีในการบุกรุกเว็บไซต์ด้วยวิธีอื่น ๆ ที่แปลกใหม่เพิ่มขึ้นอีก